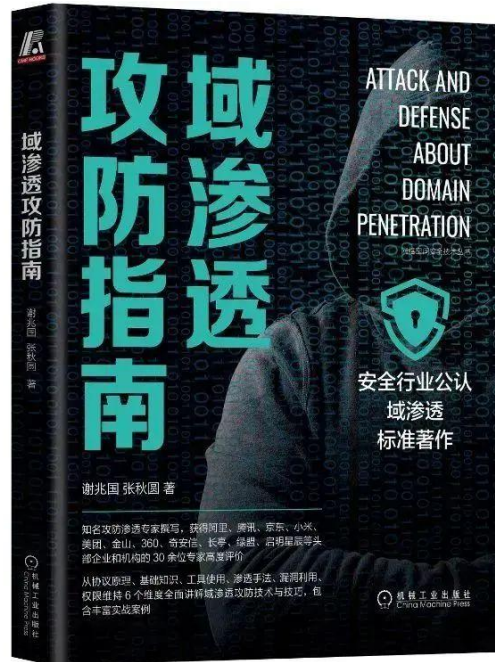


证书模板的管理

本文部分节选自《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

证书模板 Certificate templates 是 CA 证书颁发机构的一个组成部分，是证书策略中的重要元素，是用于证书注册、使用和管理的一组规则和格式。当 CA 收到对证书的请求时，必须对该请求应用一组规则和设置，以执行所请求的功能，例如证书颁发或更新。这些规则可以是简单的，也可以是复杂的，也可以适用于所有用户或特定的用户组。证书模板是在 CA 上配置并应用于传入证书请求的一组规则和设置。证书模板还向客户机提供了关于如何创建和提交有效的证书请求的说明。基于证书模板的证书只能由企业 CA 颁发。这些模板存储在活动目录域服务(ADDS)

中，以供林中的每个 CA 使用。这允许 CA 始终能够访问当前标准模板，并确保跨林一致的应用。

证书模板通过允许管理员发布已为选定任务预先配置的证书，可以大大简化管理证书颁发机构(CA)的任务。证书模板管理单元允许管理员执行以下任务：

- 查看每个证书模板的属性。
- 复制和修改证书模板。
- 控制哪些用户和计算机可以读取模板并注册证书。
- 执行与证书模板相关的其他管理任务。

证书模块的查看和修改

如图所示，使用 certtmpl.msc 命令打开证书模板控制台，可以看到系统默认的证书模板。

证书模板控制台			
文件(F) 操作(A) 查看(V) 帮助(H)			
证书模板(AD01.xie.com)			
模板显示名称	架构版本	版本	预期用途
证书颁发机构交换	2	106.0	私钥存档
目录电子邮件复制	2	115.0	目录服务电子邮件复制
密钥恢复代理	2	105.0	密钥恢复代理
Kerberos 身份验证	2	110.0	客户端身份验证, 服务器身份验证, 智能卡登录, KDC 身份验证
域控制器身份验证	2	110.0	客户端身份验证, 服务器身份验证, 智能卡登录
RAS 和 IAS 服务器	2	101.0	客户端身份验证, 服务器身份验证
工作站身份验证	2	101.0	客户端身份验证
OCSP 响应签名	3	101.0	OCSP 签名
用户	1	3.1	
仅用户签名	1	4.1	
智能卡用户	1	11.1	
通过身份验证的会话	1	3.1	
智能卡登录	1	6.1	
基本 EFS	1	3.1	
管理员	1	4.1	
EFS 恢复代理	1	6.1	
代码签名	1	3.1	
信任列表签名	1	3.1	
注册代理	1	4.1	
Exchange 注册代理(脱机申请)	1	4.1	
注册代理(计算机)	1	5.1	
计算机	1	5.1	
域控制器	1	4.1	
Web 服务器	1	4.1	
根证书颁发机构	1	5.1	
从属证书颁发机构	1	5.1	
IPSec	1	8.1	
IPSec (脱机申请)	1	7.1	
路由器(脱机申请)	1	4.1	
CEP 加密	1	4.1	
Exchange 用户	1	7.1	
仅 Exchange 签名	1	6.1	
交叉证书颁发机构	2	105.0	

如果想查看或修改某个模板的属性，可以选中该模板，然后右键—>“属性(R)”进行查看。由于系统默认的模板绝大部分不可修改属性，因此使用这种方式查看的模板属性较少。我们可以通过复制模板操作来查看模板更多的属性，选中要查看属性的模板，右键—>“复制模板(U)”，会弹出新模板的属性配置窗口，在这个窗口可以查看模板全部的属性。如图所示，我们查看“域控制器身份验证”复制模板的属性。

帮助

如果想修改属性的值，可以直接修改，然后应用——>确定即可。

如图所示，将证书的有效期修改为了 2 年：

域控制器身份验证 属性

使用者名称	发布要求	取代模板	扩展	安全	服务器
常规	兼容性	请求处理	加密	密钥证明	

模板显示名称(E):
域控制器身份验证

模板名(T):
DomainControllerAuthentication

有效期(V):
2 年

续订期(R):
6 周

☐ 在 Active Directory 中发布证书(P)
☐ 如果 Active Directory 中有一个重复证书，不要自动重新注册(D)

确定 取消 应用(A) 帮助

注：我们不建议对系统默认的证书模板进行修改，如果想修改的话，建议先复制一个模板，然后再对其进行修改！

复制证书模板

如果想要复制某个模板，可以选中该模板，然后右键——>复制模板(U)即可。

如图所示，复制“域控制器身份验证”模板。



然后会弹出新模板的属性选择框。如果要修改某些属性，直接修改即可。如果不修改属性，直接确定即可。如图所示：

新模板的属性

服务器

发布要求

取代模板

扩展

安全

兼容性

常规

请求处理

加密

密钥证明

使用者名称

模板显示名称(E):

域控制器身份验证 的副本

模板名(I):

域控制器身份验证 的副本

有效期(V):

续订期(R):

2 年

6 周

☐ 在 Active Directory 中发布证书(P)

☐ 如果 Active Directory 中有一个重复证书，不要自动重新注册(D)

确定

取消

应用(A)

帮助

之后，我们就可以在系统默认模板中看到我们复制的模板了。如图所示：



证书模板的属性

我们现在来看看模板中这些属性的含义，就以刚刚复制的“域控制器身份验证的副本”模板为例，如下：

使用者名称

使用者名称定义了如何构建证书的专有名称：

- 在请求中提供；
- 由来自请求证书的主体在活动目录中的信息来生成；

如果是来自请求证书的主体在活动目录中的信息来生成，其使用者名称的格式，有以下选项：

- DNS 名称；
- 公用名；
- 完全可分辨名称；
- 无；

是否将这个信息包括在另一个使用者名称中，这里有四个复选框：

- 电子邮件名(E)；

- DNS 名(D);
- 用户主体名称(UPN)(U);
- 服务的主体名称(SPN)(V);

如图所示，可以看到该模板生成的证书的专有名称由来自请求证书的主体在活动目录中的信息来生成，使用者名称的格式是无，是否将这个信息包括在另一个使用者名称中选中的复选框为 DNS 名(D)。

域控制器身份验证 的副本 属性

?

X

常规	兼容性	请求处理	加密	密钥证明
使用者名称	发布要求	取代模板	扩展	安全
				服务器

☐ 在请求中提供(S)

☐ 使用现有证书中的使用者信息完成自动注册续订请求(W) (*)

☒ 用 Active Directory 中的信息生成(B)

要加强使用者名称之间的一致性并简化证书管理，请选择这个选项。
 使用者名称格式(N):
 无
 ☐ 在使用者名称中包括电子邮件名(I)
 将这个信息包括在另一个使用者名称中:

☐ 电子邮件名(E)
 ☒ DNS 名(D)
 ☐ 用户主体名称(UPN)(U)
 ☐ 服务的主体名称(SPN)(V)

* 由于兼容性设置而禁用了控件。

确定

取消

应用(A)

帮助

发布要求

发布要求属性定义了要申请证书需要哪些条件。

如图所示，可以看到并未勾选“CA 证书管理程序批准(C)”选项。那么有注册证书权限的用户即可申请证书。

域控制器身份验证 的副本 属性
?
x

常规	兼容性	请求处理	加密	密钥证明
使用者名称	发布要求	取代模板	扩展	安全
	服务器			

要注册，则要求下列条件:

☐ CA 证书管理程序批准(C)

☐ 授权签名的数量(H):

0

如果你需要一个以上的签名，则不允许自动注册。

签名中要求的策略类型(P):

应用程序策略(O):

颁发策略(S):

添加(D)...

删除(R)

要重新注册，则要求下列条件:

☒ 跟注册一样使用相同标准(M)

☐ 有效的现存证书(E)

☐ 允许基于密钥的续订(K) (*)

要求在证书请求中提供使用者信息。

* 由于兼容性设置而禁用了控件。

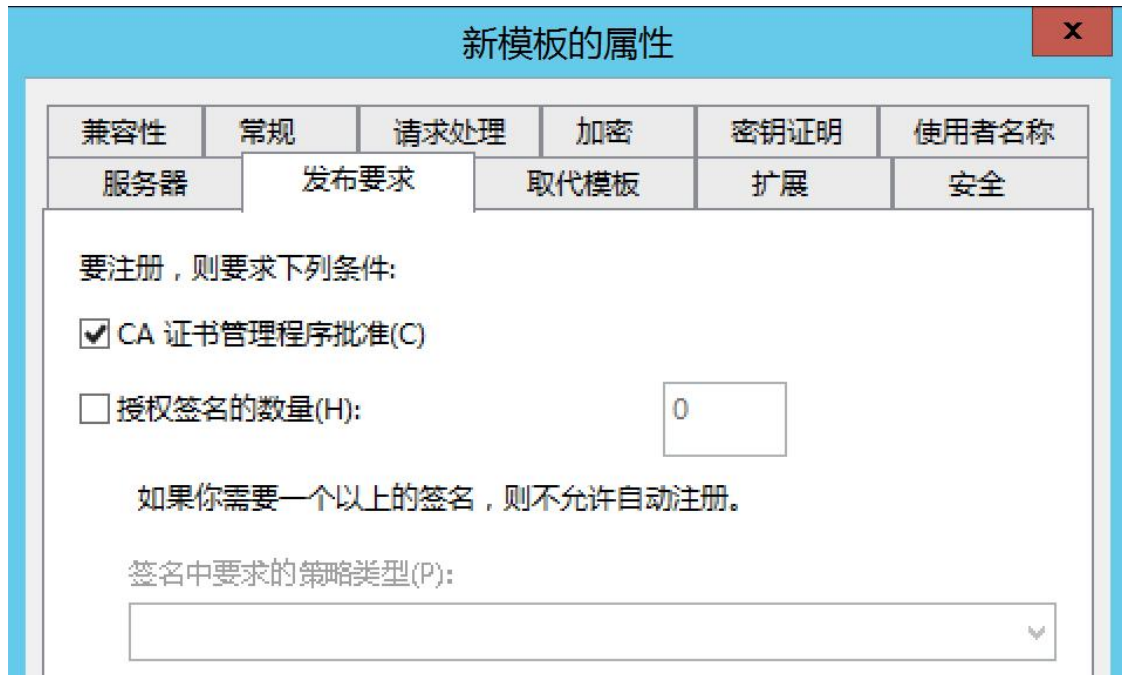
确定

取消

应用(A)

帮助

如果勾选了“CA 证书管理程序批准(C)”选项，会在证书模板 AD 对象的 msPKI-Enrollment-Flag 属性上设置 CT_FLAG_PEND_ALL_REQUESTS (0x2) 位。



这会将基于该模板的所有证书注册请求置于待处理状态（Pending Requests，在 certsrv.msc 的“挂起的申请”部分中可见），这需要证书管理员在颁发证书之前予以批准或拒绝，如下图所示。



发布要求中显示的第二组限制是“授权签名的数量(H)”和“应用程序策略”。前者要求证书请求在证书被颁发之前由现有的授权证书进行数字签名，该设置就定

义了 CSR 中 CA 接受的签名数量。后者定义了颁发证书所需的签名证书必须具有的 EKU OID。这些设置的常见用途是注册代理 (Enrollment Agents)，其表示可以代表其他用户请求证书的实体。为此，CA 必须向注册代理帐户颁发至少包含证书请求代理 EKU (OID 1.3.6.1.4.1.311.20.2.1) 的证书。一旦颁发，注册代理就可以代表其他用户签署 CSR 并请求证书。而前面所说的“授权签名的数量(H)”就指定了在 CA 考虑颁发证书之前，注册代理必须签署 CSR 的数量是多少。

新模板的属性

兼容性

常规

请求处理

加密

密钥证明

使用者名称

服务器

发布要求

取代模板

扩展

安全

要注册，则要求下列条件:

☐ CA 证书管理程序批准(C)

☒ 授权签名的数量(H):

1

如果你需要一个以上的签名，则不允许自动注册。

签名中要求的策略类型(P):

应用程序策略

应用程序策略(O):

CTL 用法

颁发策略(S):

添加(D)...

删除(R)

要重新注册，则要求下列条件:

☒ 跟注册一样使用相同标准(M)

☐ 有效的现存证书(E)

☐ 允许基于密钥的续订(K) (*)

要求在证书请求中提供使用者信息。

* 由于兼容性设置而禁用了控件。

确定

取消

应用(A)

帮助

取代模板

取代模板属性定义了此模板颁发的证书会取代该属性中所有添加到这个列表的模板所颁发的证书。

如图所示，是“域控制器身份验证的副本”模板的取代模板属性：

域控制器身份验证 的副本 属性
?
x

常规

兼容性

请求处理

加密

密钥证明

使用者名称

发布要求

取代模板

扩展

安全

服务器

此模板颁发的证书会取代所有添加到这个列表的模板所颁发的证书。请只添加这类模板: 其证书允许此模板颁发的证书所许可的任务。

证书模板(C):

模板显示名称	最低支持的 CA 数
 域控制器	Windows 2000

添加(D)...

删除(M)

确定

取消

应用(A)

帮助

扩展

扩展属性定义了该模板中包含的扩展。需要注意的是应用程序策略扩展，这个扩展决定了这个模板的用途，比如说智能卡登录、服务器身份验证、客户端身份验证等等。经过测试，应用程序策略中包含如下用途的证书可用于 Kerberos 身份认证：

- 客户端身份验证，对应的 OID 为 1.3.6.1.5.5.7.3.2
- PKINIT 客户端身份验证，对应的 OID 为 1.3.6.1.5.2.3.4，默认情况下，没有该 OID，需要手动添加
- 智能卡登录，对应的 OID 为 1.3.6.1.4.1.311.20.2.2
- 任何目的，对应的 OID 为 2.5.29.37.0
- 子 CA

此外，Specterops 发现可以滥用的另一个 EKU OID 是证书申请代理，对应的 OID 为 1.3.6.1.4.1.311.20.2.1。除非设置了特定限制，否则具有此 OID 的证书可用于代表其他用户申请证书。

fcmit.cc

编辑应用程序策略

为此策略输入一个新名称。

名称(N):

证书申请代理

对象标识符(O):

1.3.6.1.4.1.311.20.2.1

如图所示，是“域控制器身份验证的副本”模板的扩展属性：

域控制器身份验证 的副本 属性
?
x

常规	兼容性	请求处理	加密	密钥证明
使用者名称	发布要求	取代模板	扩展	安全 服务器

要更改扩展，请选择它，然后单击“编辑”。

这个模板中包括的扩展(X):

 颁发策略
 基本约束
 密钥用法
 应用程序策略
 证书模板信息

编辑(E)...

应用程序策略 的描述(D):

智能卡登录
服务器身份验证
客户端身份验证

确定
取消
应用(A)
帮助

安全

安全属性也就是该证书模板的访问控制列表，定义了哪些对象对该模板有哪些权限，比如注册、读取、写入等权限。如图所示是域控制器身份验证模板的属性，可以看到普通用户只对其具有读取的属性。

域控制器身份验证 的副本 属性
?
x

常规	兼容性	请求处理	加密	密钥证明
使用者名称	发布要求	取代模板	扩展	安全
服务器				

组或用户名(G):

Authenticated Users

Enterprise Read-only Domain Controllers (XIE\Enterprise Read-o...
Administrator (Administrator@xie.com)
Domain Admins (XIE\Domain Admins)
Domain Controllers (XIE\Domain Controllers)
Enterprise Admins (XIE\Enterprise Admins)
ENTERPRISE DOMAIN CONTROLLERS

添加(D)...
删除(R)

Authenticated Users 的权限(P)

	允许	拒绝
完全控制	☐	☐
读取	☒	☐
写入	☐	☐
注册	☐	☐
自动注册	☐	☐

有关特殊权限或高级设置，请单击“高级”。

高级(V)

确定

取消

应用(A)

帮助

常规

常规属性定义了证书的有效期和续订期。

如图所示，可以看到该模板证书的有效期默认为 1 年，证书的续订期默认为 6 周。

域控制器身份验证 的副本 属性
?
x

使用者名称	发布要求	取代模板	扩展	安全	服务器
常规	兼容性	请求处理	加密	密钥证明	

模板显示名称(E):

域控制器身份验证 的副本

模板名(T):

域控制器身份验证 的副本

有效期(V):

1 年

续订期(R):

6 周

☐ 在 Active Directory 中发布证书(P)

☐ 如果 Active Directory 中有一个重复证书，不要自动重新注册(D)

确定

取消

应用(A)

帮助

兼容性

兼容性属性定义了该模板兼容的证书颁发机构和证书接收人。

如图所示，可以看到该模板兼容的证书颁发机构为 Windows Server 2003，兼容的证书接收人为 Windows Xp 和 Windows Server 2003。

域控制器身份验证 的副本 属性
?
x

使用者名称	发布要求	取代模板	扩展	安全	服务器
常规	兼容性	请求处理	加密	密钥证明	

可用的模板选项基于在“兼容性设置”中设置的最早操作系统版本。

☒ 显示产生的变化(S)

兼容性设置

证书颁发机构(N)

Windows Server 2003
v

证书接收人(R)

Windows XP / Server 2003
v

这些设置可能不会禁止早期版本的操作系统使用此模板。

确定

取消

应用(A)

帮助

请求处理

请求处理属性定义了证书的目的，以及该证书能否允许导出私钥等。

如图所示，可以看到该模板证书的目的是签名和加密，并且不允许导出私钥。

域控制器身份验证 的副本 属性

使用者名称

发布要求

取代模板

扩展

安全

服务器

常规

兼容性

请求处理

加密

密钥证明

目的(P):

签名和加密

☐ 删除吊销的或过期的证书(不存档)(D)

☐ 包括使用者允许的对称算法(N)

☐ 把使用者的加密私钥存档(H)

☐ 授权其他服务帐户访问私钥(Z) (*)

密钥权限(K)...

☐ 允许导出私钥(O)

☐ 使用相同密钥续订(W) (*)

☐ 对于智能卡证书的自动续订，如果无法创建新密钥，则使用现有密钥(F) (*)

当使用者已经注册，并且使用了与该证书相关的私钥，执行以下操作:

☒ 注册证书使用者时无需用户输入(E)

☐ 注册时提示用户(R)

☐ 在使用私钥的情况下，注册时提示用户并要求用户输入(U)

* 由于兼容性设置而禁用了控件。

确定

取消

应用(A)

帮助

加密

加密属性定义了加密服务提供程序(CSP)和最小密钥大小。

如图所示，可以看到该模板证书的加密服务提供程序为 Microsoft RSA SChannel Cryptographic Provider，最小密钥大小为 2048。

域控制器身份验证 的副本 属性
?
X

使用者名称	发布要求	取代模板	扩展	安全	服务器
常规	兼容性	请求处理	加密	密钥证明	

提供程序类别(P):
旧加密服务提供程序

算法名称(N):
由 CSP 决定

最小密钥大小(K):
2048

选择哪些加密提供程序可以用于请求

☐ 请求可以使用该使用者的计算机上可用的任何提供程序(R)

☒ 请求必须使用下列提供程序之一(M):

提供程序(D):

☒ Microsoft RSA SChannel Cryptographic Provider
☐ Microsoft Base Smart Card Crypto Provider
☐ Microsoft DH SChannel Cryptographic Provider
☐ Microsoft Enhanced Cryptographic Provider v1.0
☐ Microsoft Enhanced DSS and Diffie-Hellman Cryptographic
☐ Microsoft Enhanced RSA and AES Cryptographic Provider

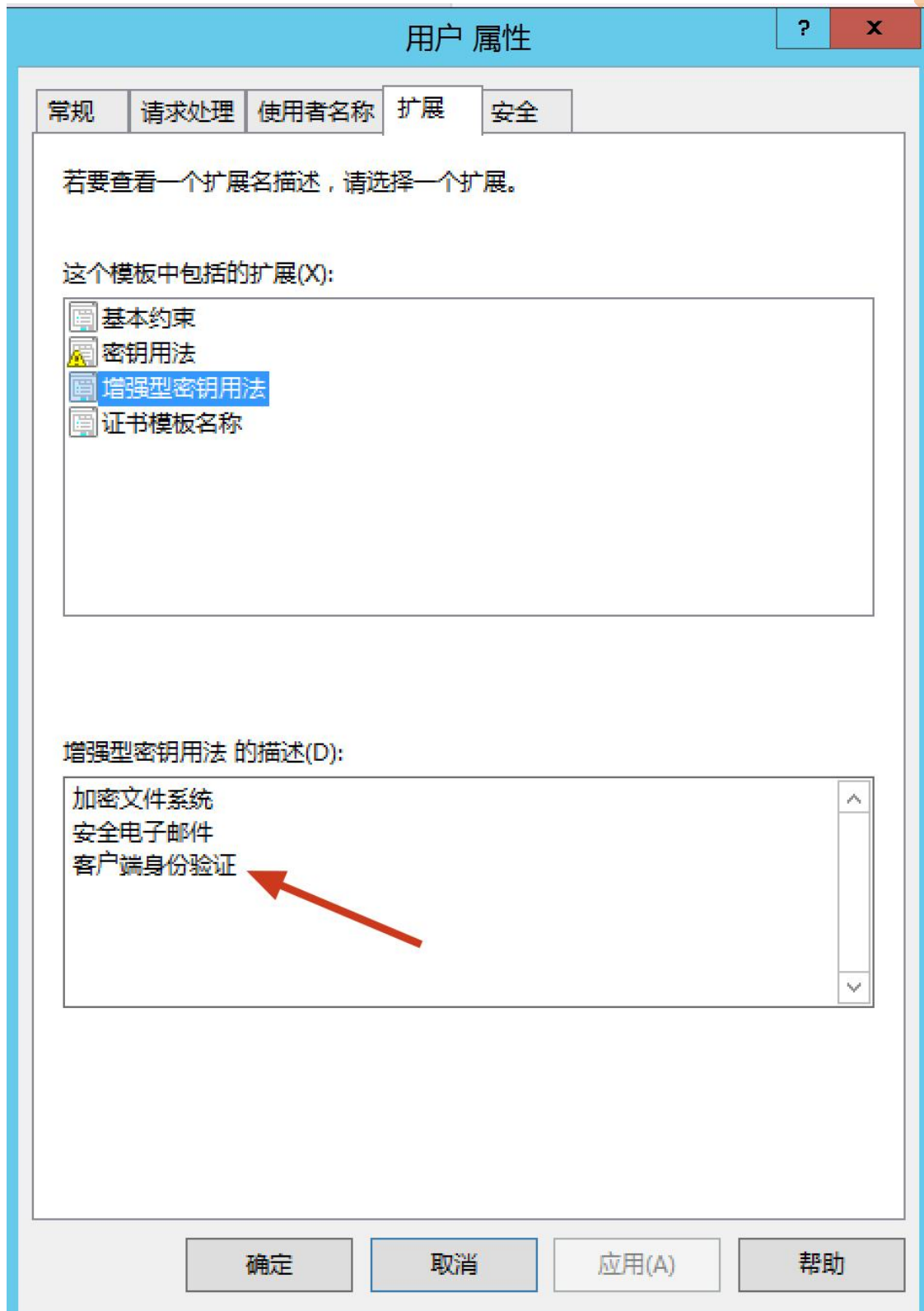
请求哈希(H):
由 CSP 决定

☐ 使用备用签名格式(U)

确定
取消
应用(A)
帮助

用户模板

用户模板是默认的证书模板。如图所示，可以看到其扩展属性里有客户端身份验证，因此用户模板申请的证书可以用于 Kerberos 身份认证。



如图所示，可以看到默认情况下 Domain Users 都有权限注册用户模板的证书。

用户 属性

?

X

常规

请求处理

使用者名称

扩展

安全

组或用户名(G):

Authenticated Users

Domain Admins (XIE\Domain Admins)

Domain Users (XIE\Domain Users)

Enterprise Admins (XIE\Enterprise Admins)

添加(D)...

删除(R)

Domain Users 的权限(P)

	允许	拒绝
完全控制	☐	☐
读取	☐	☐
写入	☐	☐
注册	☒	☐

有关特殊权限或高级设置，请单击“高级”。

高级(V)

确定

取消

应用(A)

帮助

如图所示，使用 certipy 执行如下命令以普通用户 hack 权限申请注册一个用户模板的证书。

```
certipy req -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -target 10.211.55.8 -ca xie-CA-SERVER-CA -template User -debug
certipy auth -pfx hack.pfx -dc-ip 10.211.55.4 -debug
```

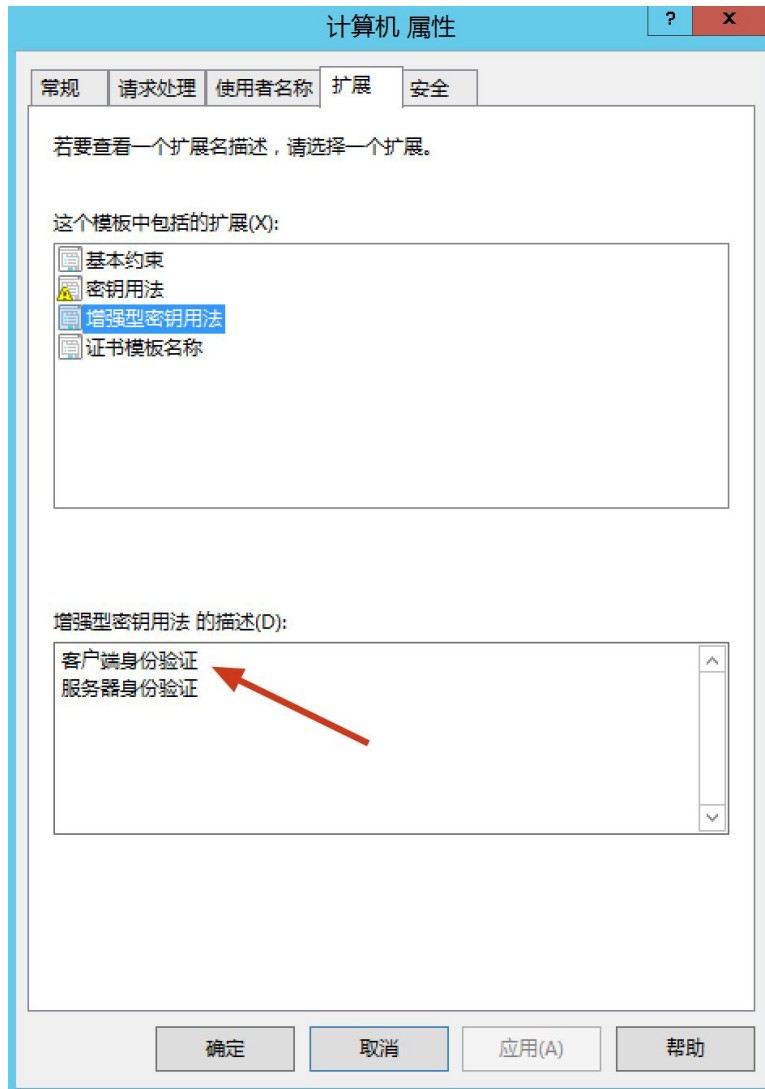
```
+ Desktop certipy req -u hack@xie.com -p P@ss1234 -dc-ip 10.211.55.4 -target 10.211.55.8 -ca xie-CA-SERVER-CA -template User -debug
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Generating RSA key
[*] Requesting certificate via RPC
[*] Trying to connect to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[*] Connected to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 47
[*] Got certificate with UPN 'hack@xie.com'
[*] Certificate has no object SID
[*] Saved certificate and private key to 'hack.pfx'
+ Desktop certipy auth -pfx hack.pfx -dc-ip 10.211.55.4 -debug
Certipy v4.0.0 - by Oliver Lyak (ly4k)

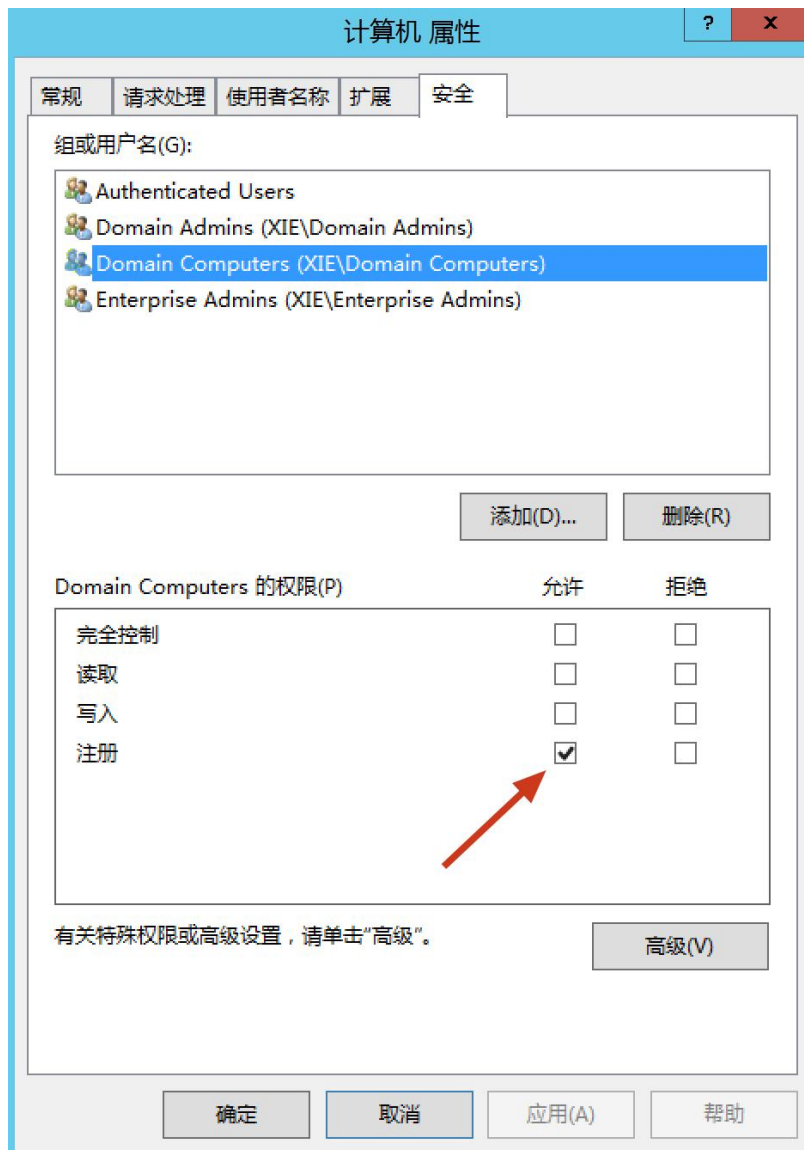
[*] Using principal: hack@xie.com
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'hack.ccache'
[*] Trying to retrieve NT hash for 'hack'
[*] Got hash for 'hack@xie.com': aad3b435b51404eeaad3b435b51404ee:74520a4ec2626e3638066146a0d5ceae
```

计算机模板

计算机模板是默认的证书模板。如图所示，可以看到其扩展属性里有客户端身份验证，因此计算机模板申请的证书可以用于 Kerberos 身份认证。



如图所示，可以看到默认情况下 Domain Computers 都有权限注册计算机模板的证书。



使用 certipy 执行如下命令以普通机器用户 machine\$ 权限申请注册一个计算机模板的证书。

```
certipy req -u machine\$ -p root -target 10.211.55.8 -ca xie-CA-SERVER-CA  
-template Machine -debug  
certipy auth -pfx machine.pfx -dc-ip 10.211.55.4 -debug
```

fcmit.cc

```
+ Desktop certipy req -u machine\$ -p root -dc-ip 10.211.55.4 -target 10.211.55.8 -ca xie-CA-SERVER-CA -template Machine -debug
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[+] Generating RSA key
[*] Requesting certificate via RPC
[+] Trying to connect to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[+] Connected to endpoint: ncacn_np:10.211.55.8[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 48
[*] Got certificate with DNS Host Name 'machine.xie.com'
[*] Certificate has no object SID
[*] Saved certificate and private key to 'machine.pfx'
+ Desktop certipy auth -pfx machine.pfx -dc-ip 10.211.55.4 -debug
Certipy v4.0.0 - by Oliver Lyak (ly4k)

[*] Using principal: machine$@xie.com
[*] Trying to get TGT...
[*] Got TGT
[*] Saved credential cache to 'machine.ccache'
[*] Trying to retrieve NT hash for 'machine$'
[*] Got hash for 'machine$@xie.com': aad3b435b51404eeaad3b435b51404ee:329153f560eb329c0e1dea55e88a1e9
```

如果想更深更细致的了解 AD 攻防知识，可以参加《域渗透攻防》培训课程：

https://mp.weixin.qq.com/s/Sjc_yTzB5CSYVk6bhnSsiQ

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。



谢公子

我加入了这个星球，邀你一起学习



域渗透攻防指南

星主：谢公子

60+

成员数量

30+

内容数量

306

运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互
相交流互相学习，共同进步成长。

现价：¥199

微信扫码加入星球



 知识星球

 谢公子学安全